

Exchange Application RBAC

Test Plan

Validate capability, resource boundaries, additive authorization paths, and recovery.
Use the form controls to record test execution and evidence.

Workload and ownership

Application / workload	
Application client ID	
Exchange service-principal object ID	
Resource boundary / scope	
Business owner	
Security owner	
Test environment / tenant	

1. Test objectives

Prove the required application role works against an in-scope mailbox.

Prove the operation is denied for an out-of-scope mailbox.

Prove unapproved write capability is denied when only read access is intended.

Detect additive access from broader Microsoft Entra grants before declaring the Exchange boundary effective.

Exercise emergency recovery in a lab environment and preserve evidence.

Test Preconditions

Complete these discovery and setup checks before executing the authorization cases.

2. Environment and identity checks

Test environment is non-production or otherwise isolated and controlled.

An in-scope mailbox is available.

An out-of-scope mailbox is available.

A mailbox with missing or unexpected boundary attributes is available where relevant.

A protected/exclusive-scope recipient is available where relevant.

Application client ID and enterprise-application service-principal object ID are recorded.

Exchange-side service principal has been registered.

Intended resource scope or administrative-unit boundary is documented.

Existing Exchange Application RBAC assignments have been exported.

Microsoft Entra API permissions have been inventoried.

Current supported application-role/API mapping has been confirmed.

A tested recovery path exists before broad access is removed or changed.

3. Representative discovery commands

```
Connect-ExchangeOnline
```

```
Get-ManagementRole | Where-Object Name -like 'Application*'
```

```
Get-ServicePrincipal -Identity $spObjectId | Format-List *
```

```
Get-ManagementRoleAssignment -RoleAssignee $spObjectId | Format-List *
```

```
Test-ServicePrincipalAuthorization -Identity $spObjectId -Resource '<target-mailbox>'
```

Execution notes

A configuration-level authorization test is necessary but not sufficient.

Follow with a real API request using the application identity.

Record target identifiers, result, timestamps, and correlation/evidence references where available.

If an expected denial succeeds, stop the test phase and investigate all applicable authorization paths.

Authorization Test Matrix

Run each case and record the observed result and evidence.

ID	Actor	Operation	Target	Expected	Status		
A-01	Archive app	Read mailbox	In-scope mailbox	Allow	P	F	N/R
Observed result / evidence							
A-02	Archive app	Read mailbox	Out-of-scope mailbox	Deny	P	F	N/R
Observed result / evidence							
A-03	Archive app	Write mailbox	In-scope mailbox	Deny	P	F	N/R
Observed result / evidence							
A-04	Archive app	Read mailbox after scoped assignment but before broad Entra grant removal	Out-of-scope mailbox	Detect additive access if overlapping grant	P	F	N/R
Observed result / evidence							

Critical interpretation

A-04 is designed to expose additive access while a broad Entra grant remains.
Do not declare the Exchange resource boundary effective until overlapping broad grants are reviewed.

Human and Recovery Cases

Use these cases to validate cross-boundary behavior and emergency recovery.

ID	Actor	Operation	Target	Expected	Status		
H-01	Tier 1 admin	Approved Set-Mailbox parameters	In-scope test mailbox	Allow	P	F	N/R
Observed result / evidence							
H-02	Tier 1 admin	Removed sensitive parameter	In-scope test mailbox	Deny	P	F	N/R
Observed result / evidence							
H-03	Tier 1 admin	Approved operation	Out-of-scope mailbox	Deny	P	F	N/R
Observed result / evidence							
H-04	Broad admin	Write protected recipient	Exclusive-scope recipient	Deny unless matching exclusive	P	F	N/R
Observed result / evidence							
R-01	Emergency admin	Restore Exchange admin path	Lab tenant	Allow and fully audit	P	F	N/R
Observed result / evidence							

Findings and remediation

Unexpected allows / additive access

Unexpected denials

Scope or membership drift

Entra permission findings

Evidence location

Exchange Application RBAC Test Plan

Closeout and Sign-off

Complete the decision record after the authorization matrix and recovery case are resolved.

R-01 recovery evidence

- Emergency identity was available through the approved secure path.
- Normal privileged access was intentionally unavailable or unsuitable for the test.
- Only the minimum recovery action was performed.
- Temporary access was removed after recovery.
- Emergency activity was fully recorded and auditable.

Final decision

- Approved - boundary proven
- Approved with remediation
- Blocked - authorization defect
- Retest required

Sign-off and references

Test lead	
Security approver	
Date	
Change / ticket reference	

Least-privilege closeout

The final decision should account for Exchange assignments and broader Microsoft Entra grants together.
Retain evidence for both allowed and denied paths.